

Evidence Upload

User Manual

Version 2.2.8

November 2026

Secure forensic evidence collection, upload sessions,
and Chain of Custody documentation

Contents

1. Overview
2. Installing and Running
3. Quick Start Workflow
4. The Admin Panel
5. Creating an Upload Session
6. Monitoring a Session
7. Receiving Evidence — the Uploader's View
8. Triage Collection Packages
9. Revoking Sessions and the Chain of Custody PDF
10. Command-Line Reference
11. Configuration File
12. Tunnels and Remote Access
13. Security Model
14. Troubleshooting
15. Verifying Downloads and Licenses

1. Overview

Evidence Upload is a self-hosted web application for collecting digital forensic evidence from remote parties. The analyst runs the server, creates a one-time upload session, and shares a link. The remote party uploads evidence through a simple browser interface — no account, no client software. Every file is hashed on arrival, and closing the session produces a Chain of Custody PDF suitable for case documentation.

Key capabilities

- **Secure upload sessions** — HMAC-signed token + secret per session, optional IP binding to the first uploader
- **Large and resumable uploads** — chunked uploads for multi-gigabyte files with resume support
- **Integrity by default** — SHA-256 computed server-side on arrival, `.sha256` sidecar files for independent verification
- **Live admin panel** — sessions, per-file names and hashes, and activity history refresh automatically
- **Chain of Custody PDF** — generated automatically on revocation or expiry, with full evidence and activity tables
- **Triage package sharing** — publish a collection package behind a download link for the remote party
- **Alerts** — desktop, email, webhook, and log-file notifications for uploads and access anomalies
- **Tunnel support** — reach internet uploaders via Cloudflare Tunnel or bore without opening firewall ports

2. Installing and Running

2.1 Download

Download the archive for your platform from the `Releases` page of the project repository. Unix builds ship as `.tar.gz` archives — extracting restores the executable bit, so no further steps are needed:

```
# macOS (Apple Silicon)
curl -LO https://github.com/4553n/evidence-upload/releases/download/v2.2.8/evidence-upload-v2.2.8-macos-arm64.tar.gz
tar -xzf evidence-upload-v2.2.8-macos-arm64.tar.gz

# macOS (Intel) — use the -macos-amd64 archive
# Linux — use the -linux-amd64 archive
# Windows — download the .exe and run it directly
```

> **macOS note**
> If you downloaded a bare binary instead of the archive, macOS strips the executable bit and Safari's downloads quarantine it. Fix both with `chmod +x evidence-upload` and `xattr -d com.apple.quarantine evidence-upload`, or right-click → **Open** → **Open**.

2.2 First run

Start the server from a terminal. With no flags it listens on port `8443`, stores evidence in `./evidence`, and applies **secure defaults**: a public `bore` tunnel and HTTPS with an auto-generated self-signed certificate. The tunnel client is built into the application — nothing is downloaded or installed:

```
$ ./evidence-upload-v2.2.8-macos-arm64
Detected external IP: 203.0.113.44
Tunnel established: bore.pub:41739 -> localhost:8443
Evidence Upload Server v2.2.8 starting on :8443
Storage: ./evidence
Base URL: https://bore.pub:41739
Admin token: 3f2a91c0e7b4d5a8c1e2f304b5d6a7c8  (keep private; set via -admin-token or ADMIN_TOKEN)
TLS: HTTPS enabled (cert: evidence/.tls/selfsigned-cert.pem)
TLS fingerprint (SHA-256): 00:0B:85:88:D8:00:81:A7:84:4A:82:C3:BC:19:2F:…
Opening admin interface...
```

The browser opens the admin panel automatically, pre-authenticated with the admin token. Use `-no-browser` to suppress the auto-open. To run without a tunnel (pure LAN), pass `-tunnel=`; for plain HTTP, pass `-tls-selfsigned=false`.

> **The admin token is your password.**
> It is printed at every startup (or set your own with `-admin-token`). Anyone holding it has full administrative control of the server. Store it like a credential — in a password manager, not in a shared document.

> **Handling evidence over a tunnel?**
> bore tunnels are plaintext TCP. Add `-tls-selfsigned` to the startup command (or supply a real certificate with `-tls-cert` / `-tls-key`) to encrypt everything end-to-end — see §12.

3. Quick Start Workflow

1. **Create a session** in the admin panel — give it a duration and a case description (e.g. a case number).
2. **Copy the upload link** that is generated and send it to the remote party over a trusted channel.
3. **Remote party uploads** evidence — the first page access records their IP; they send IP info, then drag and drop files.
4. **Monitor progress** live in the admin panel — file names, sizes, SHA-256 hashes, and activity appear as uploads arrive.
5. **Revoke the session** when collection is done — this closes uploads and generates the Chain of Custody PDF in the case folder.

4. The Admin Panel

The admin panel at `/admin` lists every active session. The table refreshes automatically every five seconds — upload counts, file names, and hashes appear without reloading the page. The refresh pauses while the tab is hidden and resumes when you return. The admin token is shown at the top of the panel with a **Copy** button, so it can be shared or re-used without digging through the console.

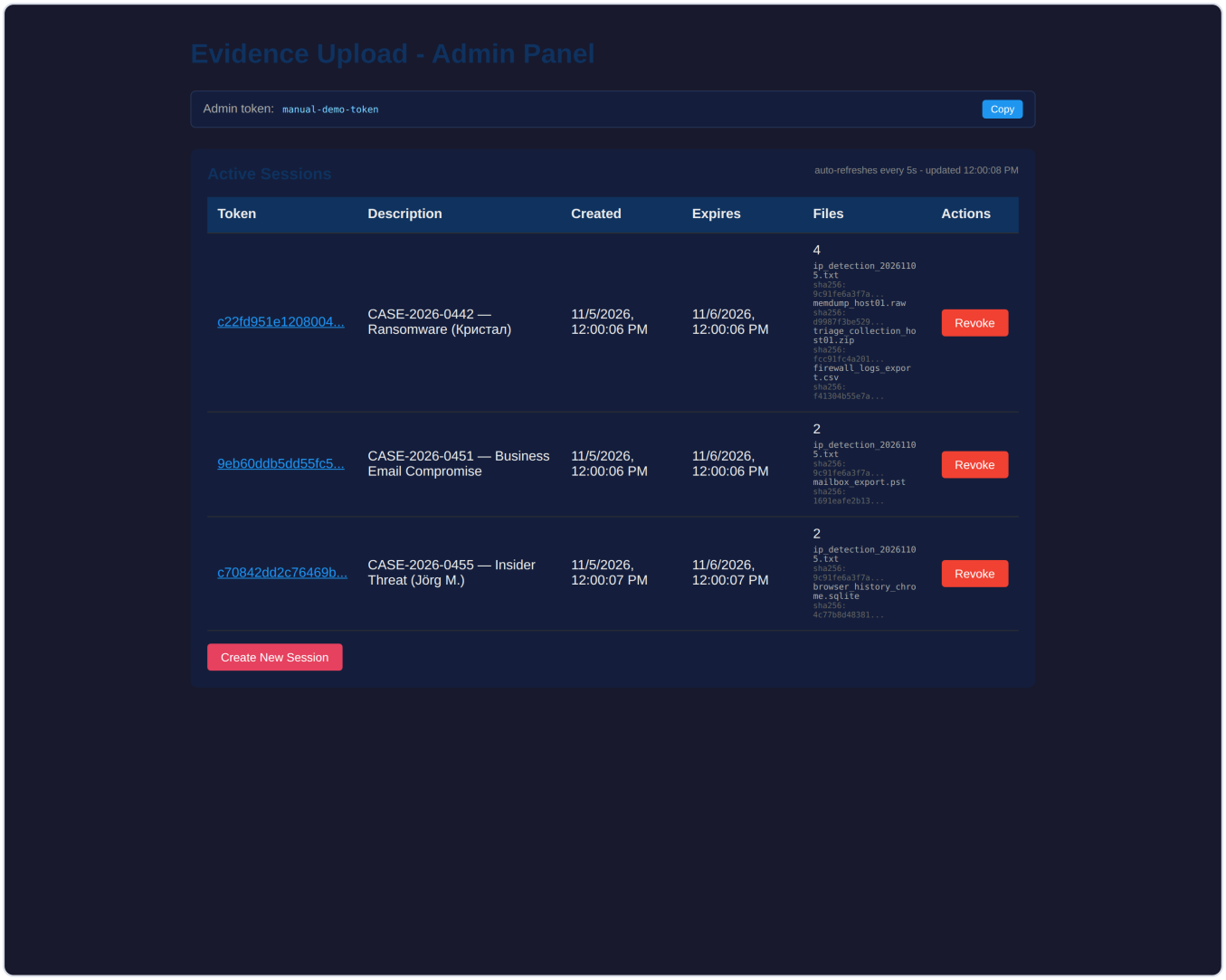


Figure 1 — The admin panel. Each row shows the session token, case description, validity window, and the uploaded files with short SHA-256 prefixes.

Table columns

Column	Meaning
Token	Session identifier — click it to open the full session detail view
Description	The case description chosen at creation; also names the evidence folder on disk
Created / Expires	Session validity window; expired sessions are cleaned up automatically
Files	Upload count, with each file name and a short SHA-256 prefix
Actions	*Revoke* — closes the session and generates the Chain of Custody PDF

5. Creating an Upload Session

Click **Create New Session**, choose how long the link should stay valid, and enter a description. Use whatever identifies the case for you — a case number, ticket ID, or short summary. The description becomes the name of the evidence folder on disk (sanitized to a safe form).

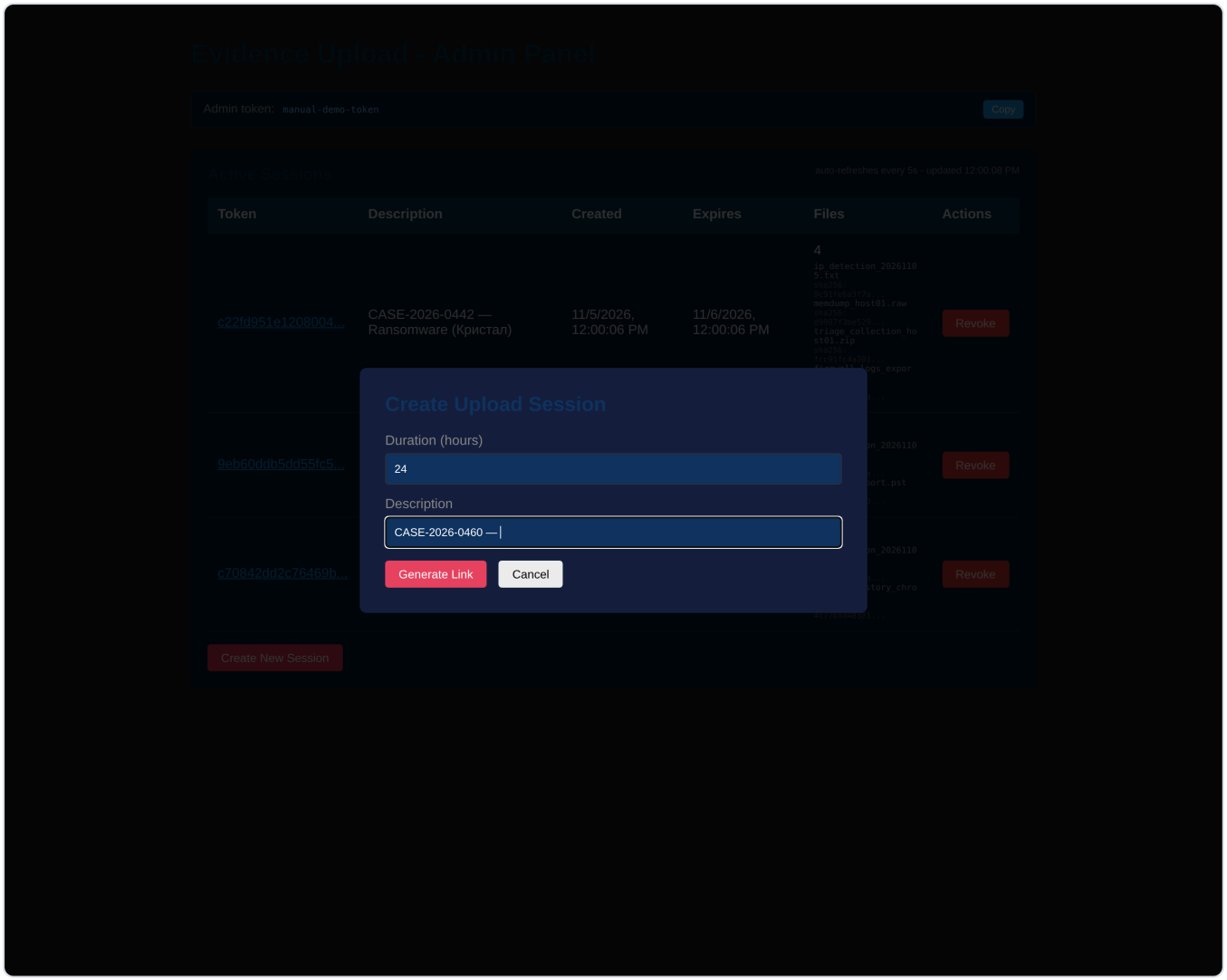


Figure 2 — The create-session dialog.

When the session is created, the panel shows a short link and the bare code:

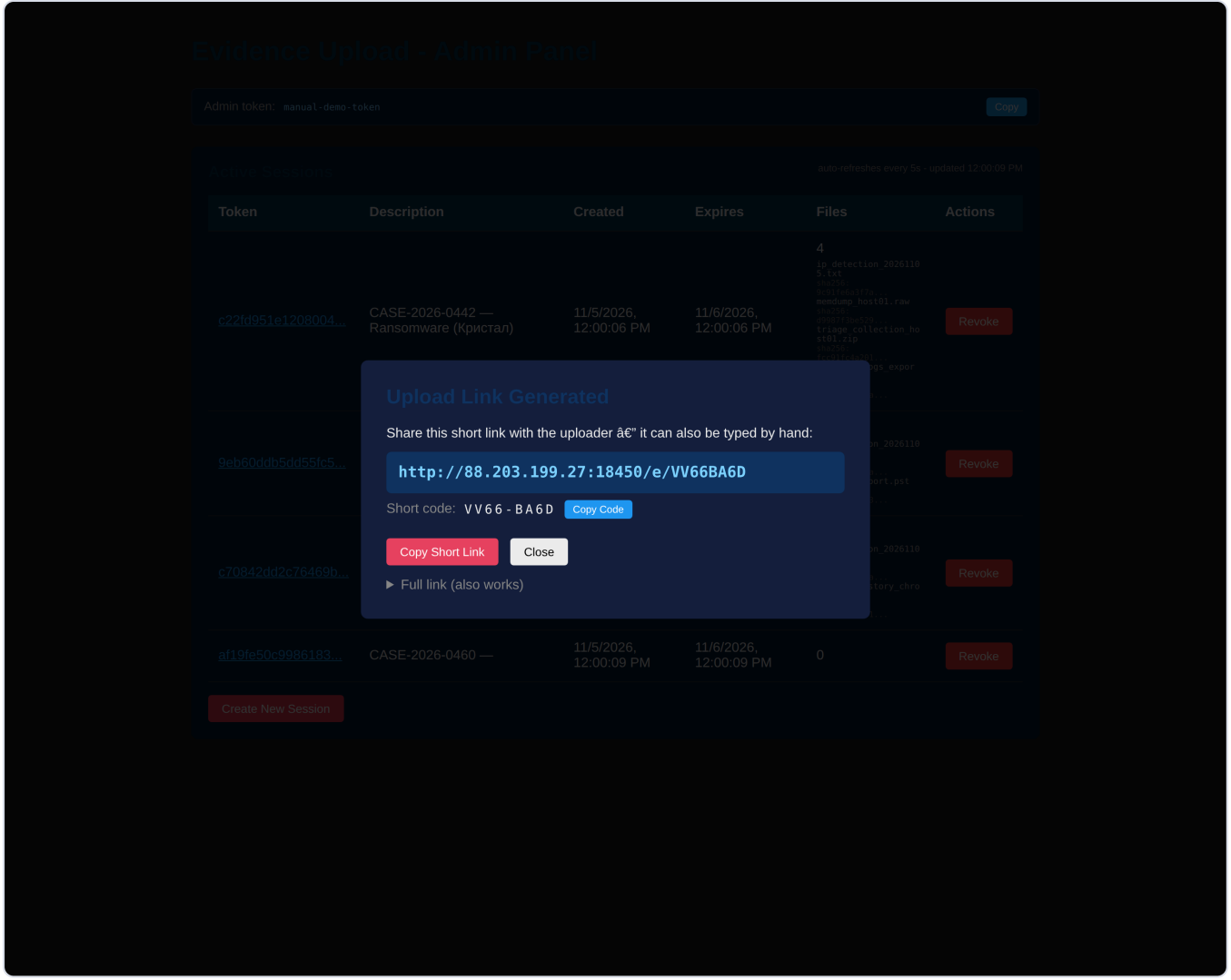


Figure 3 — The generated link dialog. The short link and code are the primary way to share access; the full link is kept underneath.

```
https://bore.pub:41739/e/K7M3-Q9P2
```

The short link is designed to be **typed by hand** when clicking is not an option — read the code aloud, dictate it over the phone, or write it on a note. Codes accept lowercase and the dash is optional (`k7m3q9p2` works too). The full `?token=…&secret=…` link keeps working as an alias, so nothing shared earlier breaks.

> **Treat the link as a bearer credential.**
> Whoever holds the short link (or the full link) can upload evidence into the case. Short codes are rate-limited — 5 failed attempts per IP within 5 minutes lock the endpoint and raise a security alert — but they are shorter than the full link, so send them only to the intended party, over a trusted channel.

6. Monitoring a Session

Click a session's token to open its detail view. It updates live while open and shows everything recorded about the session so far.

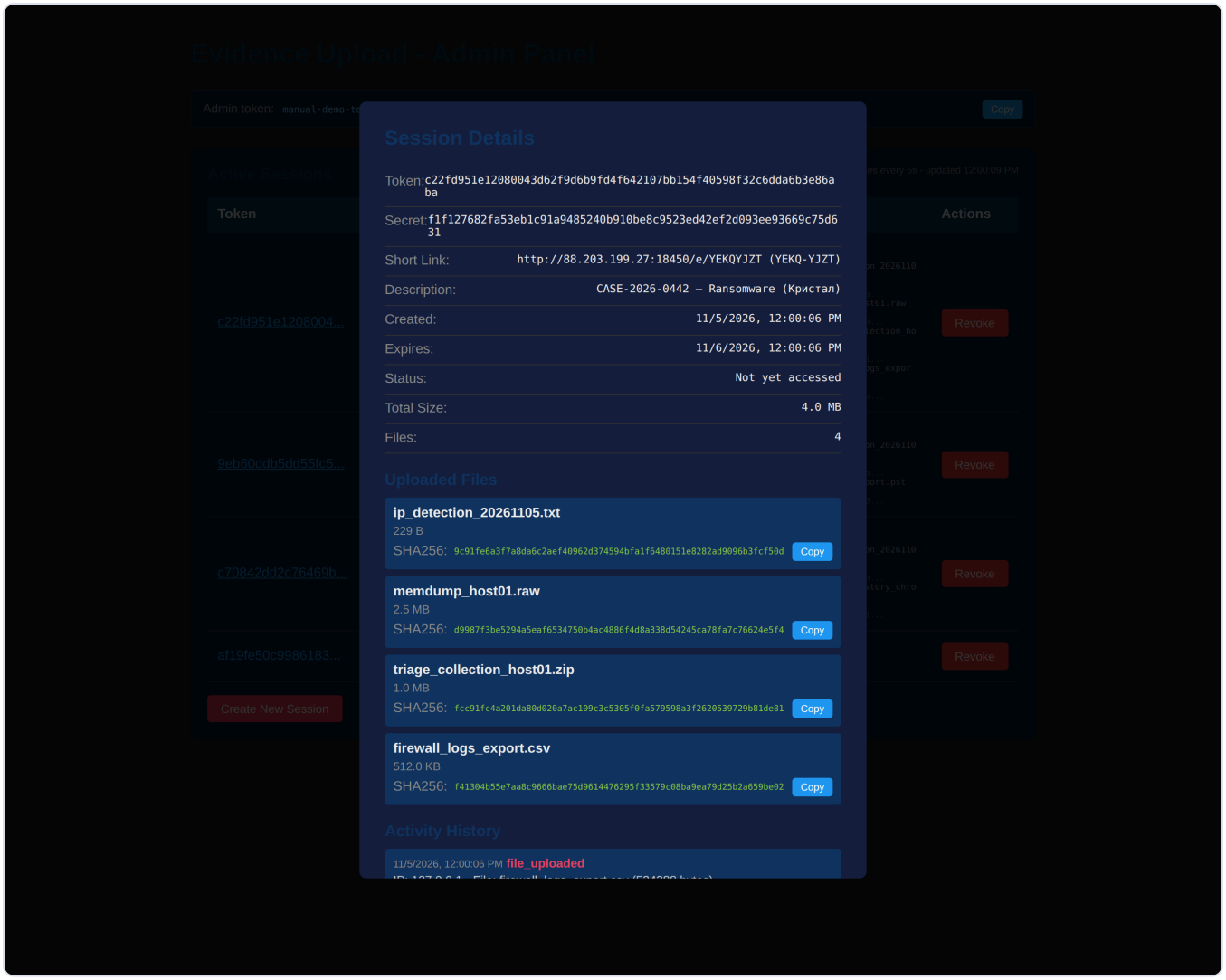


Figure 4 — Session detail: credentials, short link, per-file SHA-256 hashes with copy buttons, and the activity history.

What you see

- **Token / Secret** — the full values, so you can rebuild the upload link if needed
- **Status** — *Not yet accessed* until the uploader opens the link; afterwards it shows the IP the session is bound to
- **Total Size / Files** — running totals for the session
- **Uploaded Files** — name, size, and the *full* SHA-256 for every file, each with a **Copy** button for verification workflows
- **Activity History** — timestamped audit trail: page access, file uploads, IP information submissions, all with source IPs
- **Triage Package** — attach or replace a collection package and copy its download link (see §8)

7. Receiving Evidence — the Uploader's View

The remote party opens the upload link in any modern browser. There is nothing to install and no account to create. The page is intentionally minimal — it can only upload, never download.

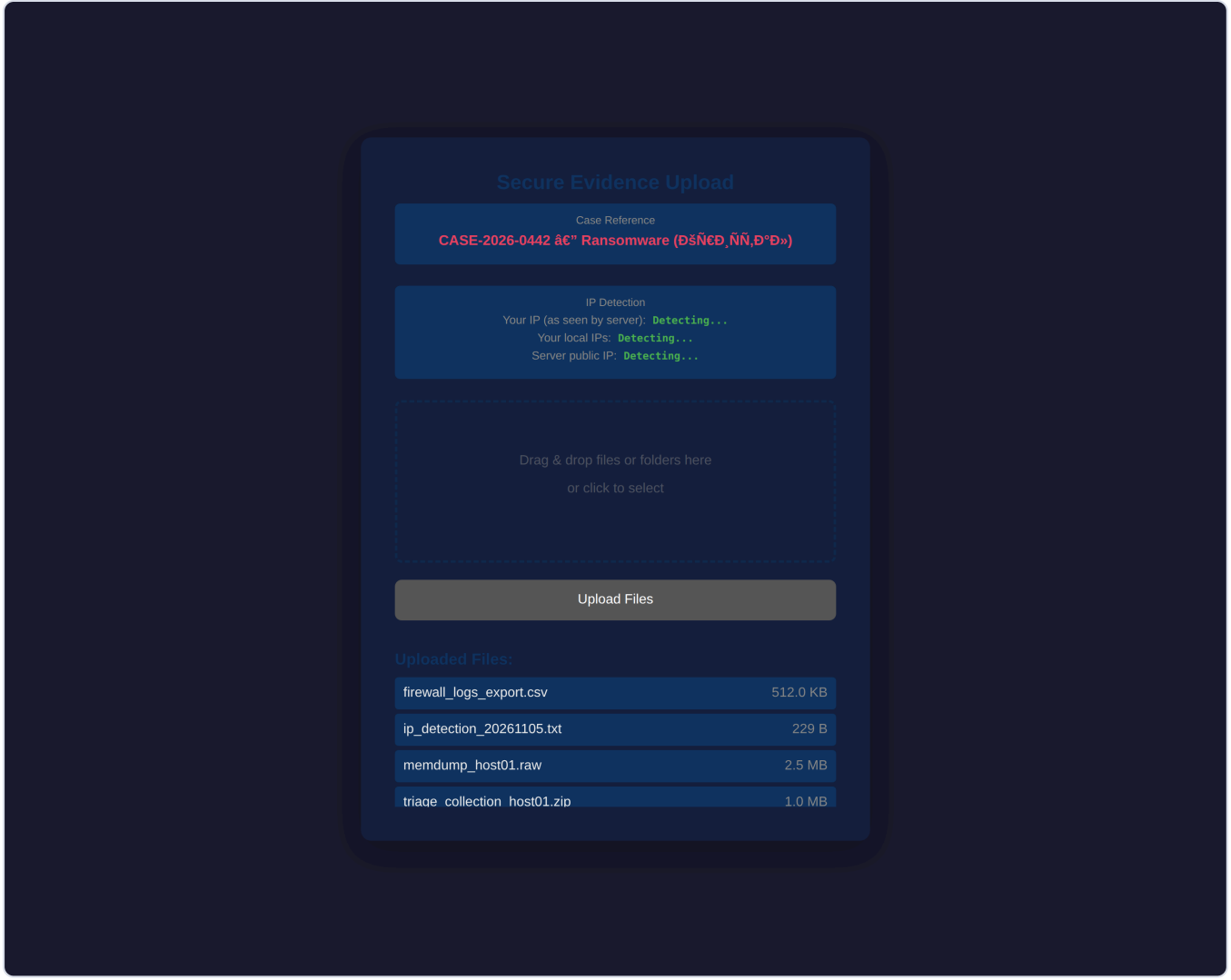


Figure 5 — The uploader's page: IP information step, drag-and-drop area, and the list of already-uploaded files with hashes.

The uploader's steps

1. **Send IP info** — the page generates an IP detection report and uploads it as the first evidence file. It documents *both sides* of the connection: the uploader's IP as seen by the server, the uploader's browser-local IPs, the server's public IP, and the server's LAN IPs, plus user agent and protocol. The file form unlocks after this step.
2. **Drop files** — drag and drop or use the file picker; multiple files are supported. Progress bars show per-file status.
3. **Large files** — files upload in chunks and can resume after an interruption without restarting from zero.
4. **Confirm** — the file list shows each completed file with its SHA-256, matching what the analyst sees.

The page also keeps an eye on the session: if the analyst revokes it or it expires, a notice appears within seconds, the upload form locks itself, and no further files can be sent.

> **IP binding**
> — the first page access locks the session to the uploader's IP. A later attempt from a different IP is rejected and raises a security alert. If the uploader's address legitimately changes, create a new session.

8. Triage Collection Packages

A triage package is a collection artifact (for example a full triage output zip) that you want to hand *to* the remote party — typically an acquisition script output or a package they must run and return. From a session's detail view, use **Send Triage Package** to upload one, or **Replace** to swap it later.

Each package gets a short download link (the session's code works here too):

```
https://bore.pub:41739/t/K7M3-Q9P2
```

> **The triage link is unauthenticated by design**
> — the code (or token) in the URL is the only protection. Share it only with the intended recipient, and revoke the session when the transfer is complete.

9. Revoking Sessions and the Chain of Custody PDF

When collection is finished, click **Revoke**. You are prompted for the analyst name that will appear on the certification block of the Chain of Custody document.

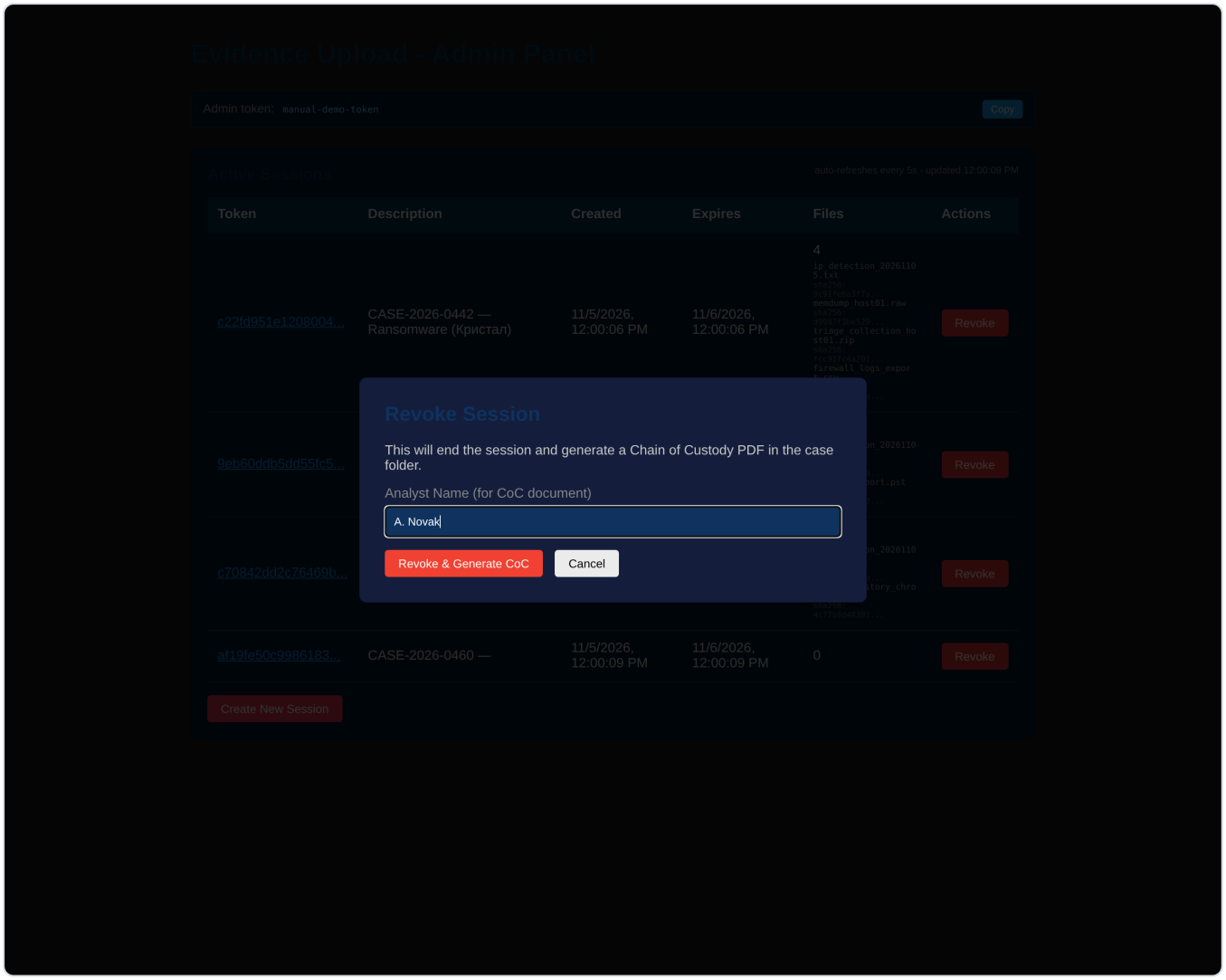


Figure 6 — The revoke dialog. Revoking closes the session for further uploads and generates the documentation.

Revoking writes `CHAIN_OF_CUSTODY.pdf` (plus a `.sha256` sidecar of the PDF itself) into the case folder next to the evidence. Sessions that expire without being revoked get the same document automatically, signed as *System (expired)*. The remote party is notified at the same moment — their upload page shows that the session was closed and locks the upload form.



CHAIN OF CUSTODY

Digital Forensic Evidence Collection Record

CASE INFORMATION

Case Description:	CASE-2026-0458 — Data Exfiltration (Acme Corp)
Session Token:	b7ad2458d0779aaff114bff66aa3da3fbeab4b7880af1c0d3741788e9ef8a68d
Created:	2026-11-05 12:00:14 EET
Expires:	2026-11-05 13:00:14 EET
Status:	REVOKED
Analyst:	A. Novak
Generated:	2026-11-05 12:00:14 EET

COLLECTOR IP INFORMATION

Uploader IP (server view)	10.20.4.117
Server Public IP:	203.0.113.44
Protocol:	HTTP/1.1
User Agent:	Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) Safari/605.1.15

EVIDENCE ITEMS

Filename	Size	SHA-256 Hash
ip_detection_20261105.txt	229 B	9c91fe6a3f7a8da6c2aef40962d374594bfa1f64...
firewall_logs_export.csv	512.0 KB	f41304b55e7aa8c9666bae75d9614476295f3357...

ACTIVITY TIMELINE

Timestamp	Action	IP Address	Details
2026-11-05 12:00:14	file_uploaded	127.0.0.1	File: ip_detection_20261105.txt (229 bytes)
2026-11-05 12:00:14	file_uploaded	127.0.0.1	File: firewall_logs_export.csv (524288 bytes)

INTEGRITY VERIFICATION

Total Files:	2
Total Size:	512.2 KB
HMAC Token:	b7ad2458d0779aaff114bff66aa3da3fbeab4b7880af1c0d3741788e9ef8a68d
Session Secret:	fd6489518217f076ea8c6029b1721a5b63fd8583630e630026b27e52f1a80ff3

Each evidence file has an accompanying .sha256 sidecar file for independent integrity verification. Use 'sha256sum -c' to verify.

CHAIN OF CUSTODY CERTIFICATION

I certify that the above evidence items were collected, handled, and stored in accordance with established forensic procedures. The evidence integrity has been verified through SHA-256 cryptographic hashing.

Figure 7 — The generated Chain of Custody document: case information, collector IP details, and the evidence table with SHA-256 hashes.

The document contains

- **Case information** — description, session token, creation and expiry times, status, analyst, generation time
- **Collector IP information** — parsed from the uploader's IP detection report (uploader IP, uploader local IPs, server public IP, server LAN IP, user agent)
- **Evidence items** — every file with size and SHA-256 hash
- **Activity timeline** — the full audit trail with timestamps, actions, and source IPs

- **Integrity verification** — file count, total size, session credentials, and instructions for verifying the `.sha256` sidecars with `sha256sum -c`
- **Certification block** — analyst signature and date lines

Text in the PDF is rendered with embedded Unicode fonts (DejaVu), so case names in any script — Cyrillic, Greek, Hebrew, accented Latin — render correctly. Characters outside the fonts' coverage (emoji, CJK) are marked with a replacement glyph rather than breaking the document. The footer records the exact software version that generated the document.

10. Command-Line Reference

Flag	Default	Description
`-port`	`8443`	Server port
`-storage`	`./evidence`	Local storage path for uploaded files
`-backup`	`""`	Network share backup path (optional)
`-expire`	`24h`	Default session expiration duration
`-secret`	auto-generated	HMAC secret key
`-admin-token`	auto-generated	Admin panel token (printed at startup)
`-tls-cert`	`""`	TLS certificate file for HTTPS (use with `-tls-key`)
`-tls-key`	`""`	TLS private key file for HTTPS
`-tls-selfsigned`	`true`	Serve HTTPS with an auto-generated self-signed certificate
`-max-size`	`10737418240`	Maximum upload size in bytes (10 GB)
`-alert-email`	`""`	Email address for security alerts
`-alert-webhook`	`""`	Webhook URL for alerts (Slack/Discord/etc.)
`-alert-desktop`	`true`	Enable desktop notifications
`-alert-log`	`./alerts.log`	Log file for security alerts
`-external-ip`	auto-detected	External/public IP for internet access
`-base-url`	auto-detected	Base URL used in generated links
`-tunnel`	`bore`	Tunnel provider: `bore`, `cloudflare`, or `external` (empty value disables)
`-bore-path`	—	Deprecated: the bore tunnel client is built in, flag ignored
`-cloudflare-path`	auto-detected	Path to the cloudflared binary
`-cloudflare-domain`	`""`	Custom domain for the Cloudflare tunnel
`-cloudflare-token`	`""`	Cloudflare tunnel token (from the dashboard)
`-tunnel-name`	`""`	Named tunnel for Cloudflare (created if missing)
`-tunnel-url`	`""`	External tunnel URL (multi-analyst mode)
`-no-browser`	`false`	Don't auto-open the browser on startup
`-version`	—	Show version and exit

11. Configuration File

Settings can be persisted instead of typed on every run. Location: `~/.evidence-upload.conf` on Linux/macOS, `%USERPROFILE%\.evidence-upload.conf` on Windows.

Priority: command-line flags > environment variables > config file > defaults.

```
# ~/.evidence-upload.conf
STORAGE=/mnt/evidence/cases
BACKUP=
ADMIN_TOKEN=a-long-random-token-you-chosenya
ALERT_EMAIL=soc@example.com
ALERT_WEBHOOK=https://hooks.slack.com/services/…
TUNNEL=cloudflare
CLOUDFLARE_DOMAIN=evidence.example.com
```

After editing, protect the file: `chmod 600 ~/.evidence-upload.conf`.

12. Tunnels and Remote Access

When uploaders are on the internet, a tunnel exposes the server without opening firewall ports. A `bore` tunnel is **started by default**; choose a different provider or disable the tunnel with `-tunnel`.

Mode	Transport	Notes
`-tunnel cloudflare`	**HTTPS**	Recommended for internet exposure. Quick tunnels get a random `trycloudflare.com` URL; token-based tunnels can use your own domain. Interoperates well with Cloudflare Access.
`-tunnel bore`	Plain TCP	Default. Zero configuration — the tunnel client is built into the application (nothing downloaded or executed). bore does not encrypt traffic: pair with `-tls-selfsigned` (or `-tls-cert` / `-tls-key`) so everything inside the tunnel is encrypted end-to-end.
`-tunnel external`	Depends	For multi-analyst setups: provide the public URL with `-tunnel-url` when something else already exposes the server.

Exposure changes the threat model.
Anything reachable from the internet gets probed — usually within minutes. The admin token is mandatory precisely because of this; see §13. Prefer Cloudflare Tunnel (HTTPS) and consider putting Cloudflare Access in front of the admin panel for SSO.

13. Security Model

Control	How it works
Admin token	Every `/admin/api/*` endpoint requires it (`X-Admin-Token` or `Authorization: Bearer`). Auto-generated at startup, printed once per run; the panel prompts and remembers it for the browser session. Compared in constant time.
Session credentials	Uploads require the session's HMAC token *and* secret — both are 128-bit random values. Secrets are never included in the session list API. Sessions persist to `<storage>/.sessions.json` (owner-only permissions), so links survive server restarts.
IP binding	First access locks the session to the uploader's IP; mismatches are rejected and alerted.
Integrity	SHA-256 computed server-side per file, written as `.sha256` sidecars; the CoC PDF itself is hashed too.
Audit trail	Every action recorded with timestamp and source IP; reflected in the CoC PDF and the alert log.
Alerts	Desktop, email, webhook, and log-file notifications for uploads and access anomalies.

Known limitations
Upload and triage download links are bearer URLs — anyone holding the link has that capability. The service serves plain HTTP by default; enable TLS with `-tls-selfsigned` (zero-config) or `-tls-cert` / `-tls-key` (real certificates) so all traffic — including through plaintext tunnels like bore — is encrypted end-to-end between the browser and your server.

14. Troubleshooting

Symptom	Cause and fix
`zsh: permission denied`	The binary lost its executable bit in download. Use the `.tar.gz` release archive, or run `chmod +x` on a bare binary.
macOS: "cannot be opened because the developer cannot be verified"	Gatekeeper quarantine on downloaded binaries. Right-click → **Open** → **Open**, or clear with `xattr -d com.apple.quarantine <file>`.
"Failed to revoke session: Could not reach the server"	The browser lost the server (process stopped, tunnel dropped). Check the server terminal, restart if needed, and retry.
"Server error (HTTP 401): invalid or missing admin token"	The admin token is wrong or expired for this browser session. Reload the panel and enter the token printed at server startup.
Short link says "This link is invalid or expired"	The code does not match any session — check for typos (the letters `I`, `L`, `O`, `U` are never used). Codes are accepted in lowercase and without the dash. If it previously worked, the session may have been revoked or expired.
Short link returns "Too many attempts" (HTTP 429)	Five failed lookups from one address within 5 minutes trigger a temporary lockout; wait a few minutes and double-check the code. Repeated lockouts raise security alerts on the analyst's side.
Upload link reports a session problem	The message names the exact reason: *closed by the analyst* (revoked), *expired*, or *not found* (malformed link, or a link from a server older than v2.2.8 that lost sessions on restart). Ask the analyst for a fresh link if in doubt.
Session rejects the uploader	IP binding: the session was first accessed from a different address. Create a new session if the change is legitimate.
Admin panel shows unexpected sessions	If the server is internet-exposed, external scanners may create sessions through old, unauthenticated versions. Update to v2.2.2 or later, revoke unknown sessions, and check the activity history for source IPs.
CoC PDF missing after revoke	Check the server terminal for the error. Very long descriptions are truncated safely since v2.2.2; regenerate by revoking again or from expiry.
Browser warns about the TLS certificate	Expected with `-tls-selfsigned`: the certificate is not issued by a public authority. Verify the SHA-256 fingerprint printed at startup, then proceed; use `-tls-cert` / `-tls-key` with a real certificate to remove the warning entirely.
Garbled characters in old CoC PDFs	Fixed in v2.2.3 (embedded Unicode fonts). Documents generated by older versions remain valid; their text layer used Latin-1 fonts.

15. Verifying Downloads and Licenses

Each release ships a `SHA256SUMS` file. Verify your download:

```
$ shasum -a 256 -c SHA256SUMS        # macOS
$ sha256sum -c SHA256SUMS            # Linux
```

Licenses

- **Evidence Upload** — MIT License (see `LICENSE` in the repository)
- **DejaVu fonts** (embedded in the CoC generator) — Bitstream Vera / DejaVu license; the full text ships in `internal/custody/fonts/LICENSE-DejaVu.txt`

Evidence Upload v2.2.8 — User Manual · Generated 2026-11-05 · Interfaces shown are from the v2.2.x series.